

AVANCE DE PROYECTO INTEGRADOR

Detección de problemáticas

**Nombre del
alumno:**

Luis Alberto Vargas Gonzalez

I. Servicios de seguridad con los que cuenta la empresa

A pesar de las grandes deficiencias, la empresa implementa los siguientes mecanismos básicos:

Control de Acceso Físico por Proximidad: La empresa utiliza un sistema de gafetes de proximidad para regular la entrada de los empleados a las oficinas.

Vigilancia por Circuito Cerrado (CCTV): Se cuenta con cámaras de seguridad instaladas en las instalaciones, diseñadas para el monitoreo de los espacios físicos. Sin embargo, el caso menciona que la mayoría de estas no se encuentran operativas.

Protección de Endpoints (Antivirus): Existe un servicio de protección para los 10,000 equipos que utilizan el sistema operativo Windows, el cual consiste en la implementación de un antivirus de versión gratuita.

II. Integridad de la información

La empresa presenta una gestión de la integridad sumamente deficiente, caracterizada por la ausencia total de controles que validen la exactitud y consistencia de los datos. Los puntos clave que comprometen la integridad son:

Ausencia de Control de Acceso Lógico: No existen jerarquías de acceso ni roles definidos. Al tener todos los empleados "full access", cualquier usuario puede modificar o eliminar información crítica sin restricciones en todos los sistemas.

Falta de Trazabilidad y Auditoría: No existe un historial de cambios ni registros de mantenimiento para los equipos. Esto imposibilita identificar quién realizó una modificación, cuándo se hizo o si el cambio fue autorizado.

Instalación de Software No Controlada: Los empleados pueden instalar cualquier tipo de software desde internet sin solicitar permiso. Esto abre la puerta a que malware o aplicaciones maliciosas alteren archivos del sistema o bases de datos sin detección previa.

Inexistencia de Clasificación de Datos: Al no haber un control ni clasificación de la información, no se pueden aplicar reglas de protección específicas para asegurar que los datos más sensibles permanezcan inalterados.

III. Disponibilidad de la información

La disponibilidad de la información en esta organización se encuentra en un estado crítico, ya que diversos factores estructurales y operativos impiden asegurar que los datos y sistemas estén accesibles cuando se requieren:

Ventanas de mantenimiento excesivas e ineficientes: Los servidores requieren procesos de mantenimiento que duran más de 8 horas y pueden prolongarse por más de 2 días. Además, estos procedimientos se realizan con una frecuencia de cada 2 semanas, lo que genera interrupciones constantes en la operación.

Capacidad de respaldo insuficiente: No existe un control formal de respaldos y, ante la falta de espacio en el almacenamiento de los servidores, solo es posible respaldar una cuarta parte de la información. Esto deja al 75% de los datos en riesgo de pérdida total ante un fallo.

Infraestructura de red obsoleta: Los equipos Cisco que operan la red tienen más de 5 años sin actualizaciones, lo que aumenta significativamente la probabilidad de fallas de hardware sin posibilidad de soporte técnico inmediato.

Carencia de acceso remoto seguro: La empresa no cuenta con un proveedor de comunicaciones que ofrezca servicios de VPN, impidiendo que los empleados se conecten a los sistemas de manera remota.

Riesgos físicos y falta de planeación: El centro de diseño, ubicado en una zona sísmica, carece de un plan de evacuación claro. Sumado a esto, no existe un inventario de activos ni un control de mantenimiento preventivo, por lo que los equipos solo se cambian en situaciones de emergencia.

IV. Nivel de la confiabilidad de la información

El nivel de confiabilidad de la información en la empresa es **extremadamente bajo**, ya que no existe ninguna garantía de que los datos sean auténticos, precisos o que provengan de fuentes seguras. Esta falta de confianza se fundamenta en los siguientes puntos:

Inexistencia de un Inventario de Activos y Control de Cambios: Al no haber un registro oficial de hardware ni un historial de modificaciones, es imposible asegurar la legitimidad de los equipos conectados. Como se nota, esto facilita la sustracción de componentes internos y la introducción de dispositivos ajenos infectados con spyware o adware sin que la organización lo note.

Obsolescencia y Falta de Parches: Los motores de bases de datos (DB2, Oracle y SQL Server) operan con versiones de hace 3 años sin haber recibido parches de seguridad. Una base de datos vulnerable no es confiable, pues la información contenida puede haber sido comprometida o alterada por atacantes explotando fallos conocidos.

Uso de Software No Autorizado: La política que permite a los empleados instalar cualquier software de internet sin permiso degrada la confiabilidad de los equipos de cómputo. Esto introduce un riesgo constante de que herramientas de terceros intercepten o manipulen la información del negocio.

Falta de Gestión de Vulnerabilidades: Al no existir un proceso para actualizar los sistemas operativos y depender de un antivirus gratuito en Windows, la integridad de la plataforma donde reside la información está en duda permanente.

Ausencia de Políticas de Seguridad: Sin un marco normativo o políticas implementadas, la confiabilidad de los procesos depende únicamente de la buena voluntad del empleado, lo cual es inaceptable en un entorno de desarrollo premium.

V. Riesgos y vulnerabilidades

En esta sección se detallan las debilidades del sistema (vulnerabilidades) y los eventos negativos potenciales (riesgos) que podrían afectar a la organización:

Vulnerabilidades Identificadas:

Tecnológicas: Uso de antivirus gratuito en Windows, motores de bases de datos y sistemas operativos sin parches de seguridad desde hace 3 años, y equipo de red Cisco obsoleto sin actualizaciones en 5 años.

Administrativas: Inexistencia de un inventario de activos, falta de control de cambios, ausencia de políticas de seguridad y falta de una administración centralizada de licencias.

Lógicas: Ausencia de roles y jerarquías (acceso total para todos los empleados) y falta de una conexión segura (VPN) para el trabajo remoto.

Físicas: Cámaras de seguridad inoperativas y falta de un plan de evacuación ante sismos en el centro de diseño.

Operativas: Capacidad de respaldo limitada a solo una cuarta parte de la información y ventanas de mantenimiento excesivamente largas.

Riesgos Asociados:

Fuga o Sustracción de Activos: Debido a la falta de inventario y control de mantenimiento, existe el riesgo de robo de componentes internos de los equipos o la pérdida física de dispositivos completos sin que la empresa lo detecte oportunamente.

Compromiso por Software Malicioso: La libre instalación de software de internet y el uso de antivirus básicos facilitan la entrada de spyware, adware o ransomware.

Exfiltración de Propiedad Intelectual: Al no haber roles ni control de invitados, empleados o personas ajenas pueden acceder y copiar diseños de tecnología automotriz premium.

Interrupción Prolongada del Negocio: Los mantenimientos de hasta 2 días y la red obsoleta representan un riesgo de caída total de la producción y el desarrollo.

Pérdida Irreversible de Datos: Ante un fallo crítico de almacenamiento, el 75% de la información no cuenta con respaldo, lo que podría significar la pérdida de años de investigación y desarrollo.

Introducción de Equipos Infectados: La falta de un historial de cambios permite que dispositivos ajenos a la organización sean conectados a la red interna, propagando amenazas de forma lateral.

VI. Posturas de seguridad

En este apartado se describe la actitud actual de la organización frente al riesgo y se proponen las posturas necesarias para alcanzar un nivel de protección adecuado para una empresa de su categoría.

Postura de Seguridad Actual:

- **Postura Reactiva y Negligente:** La empresa solo actúa ante emergencias críticas, como cuando un equipo está a punto de dejar de funcionar. No existe un enfoque preventivo; se ignoran las actualizaciones de bases de datos por 3 años y del equipo de red por 5 años.
- **Postura Permisiva (Abierta):** Existe una política de "puertas abiertas" tanto digital como física. No hay jerarquías de acceso (todos tienen *full access*), no hay políticas de seguridad implementadas, y se permite a los empleados instalar cualquier software sin supervisión.
- **Postura de Desinterés en el Cumplimiento:** No existe un inventario de activos, control de licencias o historial de cambios. Además, se opera con herramientas insuficientes como antivirus gratuitos para una fuerza laboral de 10,000 usuarios de Windows.

Posturas de Seguridad que harían falta:

- **Postura Proactiva y de Prevención:** Es urgente implementar un programa de gestión de parches y actualizaciones periódicas para cerrar las brechas de seguridad en sistemas operativos y motores de bases de datos.
- **Postura de "Menor Privilegio":** Se debe transitar de un modelo de "acceso total" a uno basado en roles (RBAC), donde cada empleado tenga acceso únicamente a la información necesaria para sus funciones.
- **Postura de Cumplimiento y Gobierno (Normativa):** Es indispensable crear y aplicar políticas de seguridad formales, llevar un inventario riguroso de activos y establecer controles de mantenimiento preventivo.
- **Postura de Resiliencia y Continuidad:** La empresa necesita un Plan de Recuperación ante Desastres (DRP) que incluya una estrategia de respaldos completa y un plan de evacuación funcional para el centro de diseño en zona sísmica.
- **Postura Defensiva Robusta:** Sustituir soluciones gratuitas por herramientas de seguridad de grado empresarial (EDR/XDR) y establecer conexiones seguras mediante VPN para el acceso remoto.